

DEVSECOPS & PLATFORM · ISSUE 05 OF 08

Terraform at scale.

Terraform is safe when apply is boring and only the pipeline does it.

05

AR

Akhilesh Ranjan Singh

Senior DevSecOps Engineer · github.com/iarsingh

Swipe →

State

01 Remote backend with locking

GCS, Azure Storage or S3 — never local.

02 Split by blast radius

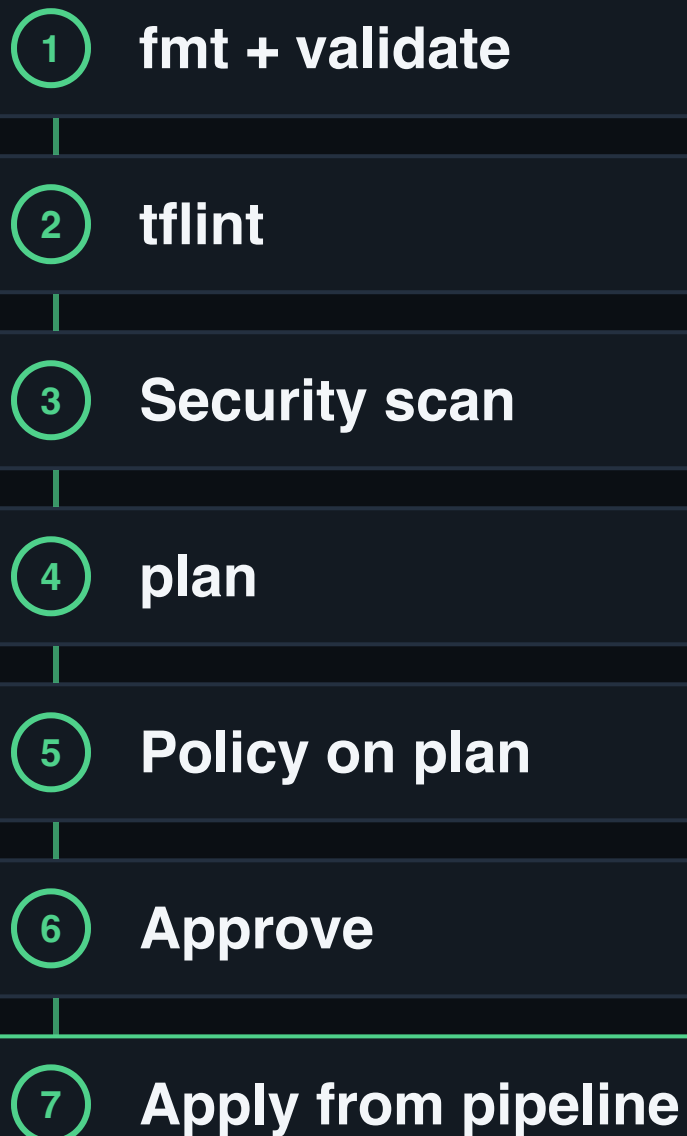
Separate state per environment and layer.

03 Never edit by hand

Use moved, import and removed blocks.



PR pipeline



The plan in the PR is the plan that gets applied.

Policy on the plan

BASH

```
terraform plan -out tfplan
terraform show -json tfplan > plan.json
conftest test plan.json --policy policy/
```

```
# nightly drift check
```

```
terraform plan -detailed-exitcode
```

```
# exit 2 = drift
```



Habits

DO

- ✓ Version modules with tags
- ✓ for_each over count for named things
- ✓ Small module interfaces
- ✓ Nightly drift detection

AVOID

- ✗ Apply from laptops
- ✗ One giant state file
- ✗ Provider blocks inside modules
- ✗ Hand-edited state

Landing zone basics

- ☒ Separate projects / subscriptions per env

- ☒ Central logging and audit

- ☒ Private networking + controlled egress

- ☒ Org policies as guardrails

- ☒ Least-privilege pipeline identity

- ☒ Budget alerts



KEY TAKEAWAY

Remote state, plan in the PR, apply only from the pipeline.

- Split state by blast radius
- Policy-check the plan JSON
- Detect drift nightly

YOUR TURN

Does anyone still run terraform apply from a laptop in your team?

FOLLOW AKHILESH RANJAN SINGH

Next in the series: #06 SLIs, SLOs and error budgets

Save · Repost

